

CSE450 Capstone Project Report

Title of the Project

Submitted by

Student Name	Student ID
Student Name	Student ID
Student Name	Student ID
Student Name	Student ID
Student Name	Student ID

Supervised by

Supervisor Name
Designation, Department of CSE, BUET



Department of Computer Science and Engineering
Bangladesh University of Engineering and Technology
Dhaka, Bangladesh

Session 20XX–20XX
Month YYYY

CANDIDATES' DECLARATION

We declare that the work presented in this report, titled "Title of the Project", is the outcome of the engineering work carried out by us under the supervision named on the title page.

All prior work, third-party code, libraries, data, copyrighted material, and tools used in the project have been properly acknowledged. Any use of generative AI tools has been disclosed. We accept accountability and responsibility for the accuracy and integrity of this report and for our individual contributions to the project.

Student Name (ID)

Student Name (ID)

Student Name (ID)

Student Name (ID)

Student Name (ID)

ACKNOWLEDGEMENT

Thank your supervisor, and anyone else who helped: domain experts, collaborators, users who tested the system, people from other departments or organisations you consulted.

ABSTRACT

In no more than one page, state the problem, what was designed and built, how it was verified or validated, and the key outcomes. For a research-oriented project, briefly include the method and principal findings.

Keywords: *three to six keywords*

Contents

Candidates' Declaration	i
Acknowledgement	ii
Abstract	iii
1 Problem Identification and Formulation	1
1.1 Background and Motivation	1
1.2 Problem Statement	1
1.3 Complexity of the Problem	1
1.4 Project Objectives and Scope	1
2 Preliminary Research	3
2.1 Literature Review	3
2.2 Existing Solutions and Technologies	3
2.3 Market and User Research	3
2.4 Feasibility Study	3
3 Requirements Analysis	4
3.1 Project Objectives and Constraints	4
3.1.1 Problem Context and Origin	4
3.1.2 Requirements Elicitation	4
3.1.3 Stakeholders and Their Expectations	5
3.1.4 Conflicting Expectations and Their Resolution	5
3.1.5 Project Objectives	7
3.1.6 Functional Requirements	8

3.1.7	Non-Functional Requirements	12
3.1.8	Constraints	14
3.2	Regulatory Requirements and Standards	16
3.2.1	Scope and Approach	16
3.2.2	Data Protection and Privacy	16
3.2.3	Partner Policy and Contractual Obligations	17
3.2.4	Third-Party Terms of Service as Codes of Practice	17
3.2.5	Application Security: OWASP	18
3.2.6	Accessibility: WCAG 2.1 Level AA	20
3.2.7	Software Engineering Standards	21
3.2.8	Compliance Summary and Identified Gaps	22
3.3	Formulation of Solutions	23
4	System Design and Implementation	24
4.1	Functional Design and Sub-problem Partitioning	24
4.2	Design Refinement and Simulation	24
4.3	Application of Tools	24
4.4	Implementation	24
4.5	Deployment	25
5	Investigation and Evaluation	26
5.1	Experimental Investigation	26
5.2	Performance Evaluation	26
5.3	Deviations and Design Revisions	26
6	Project Management, Teamwork, and Impact	27
6.1	Project Management and Finance	27
6.1.1	Planning and Risk Management	27
6.1.2	Budgeting and Resource Identification	27
6.1.3	Economic Analysis and Financial Prospecting	27

6.1.4	Sustainability in Business and Commercialisation	28
6.2	Individual and Teamwork	28
6.2.1	Participation and Contribution	28
6.2.2	Collaboration and Conflict Resolution	28
6.2.3	Leadership and Direction	28
6.2.4	Multidisciplinary Engagement	28
6.3	Impact on Society	28
6.4	Environmental Impact and Life Cycle Sustainability	29
6.5	Ethics	29
6.5.1	Equity and Inclusivity	29
6.5.2	Accountability and Personal Responsibility	29
6.5.3	Proper Use of Intellectual Property	29
6.5.4	Professionalism and Ethical Codes	29
7	Conclusion	30
7.1	Conclusion and Future Work	30
7.2	Continuous Engagement and Self-directed Learning	30

List of Figures

4.1	System architecture	24
6.1	Project schedule	27

List of Tables

1.1	Complex engineering problem characteristics (P1–P7) and evidence from this project	2
1.2	Knowledge profiles referenced by P1	2
3.1	Stakeholders and their principal expectations	5
3.2	Conflicting stakeholder expectations and their resolution	6
3.3	Project objectives	7
3.4	Functional requirements: authentication, tenancy and access control	8
3.5	Functional requirements: workspace and project configuration	9
3.6	Functional requirements: metric ingestion	9
3.7	Functional requirements: health scoring and presentation	10
3.8	Functional requirements: team feedback surveys	11
3.9	Functional requirements: management action log	12
3.10	Non-functional requirements	12
3.11	Project constraints	14
3.12	Design response to the OWASP Top 10 (2021)	18
3.13	Engineering standards adopted and their application	21
3.14	Identified compliance gaps and their disposition	22

Chapter 1

Problem Identification and Formulation

1.1 Background and Motivation

Introduce the domain and explain why the problem matters: who is affected, at what scale, and what the current situation costs them.

1.2 Problem Statement

State precisely the problem the project solves. Formulate it in engineering terms: the inputs and outputs, the entities involved, the quantities to be optimised or guaranteed, and the assumptions made. Identify the engineering knowledge (mathematics, computing fundamentals, specialist knowledge) the problem demands.

1.3 Complexity of the Problem

A complex engineering problem must have characteristic P1 and some or all of P2–P7 (Table 1.1). P1 requires in-depth knowledge at the level of one or more of the knowledge profiles K3–K8 listed in Table 1.2.

For P1, name the knowledge profile(s) involved and show where in the project that knowledge was applied. For each of P2–P7 that applies, give concrete evidence from this project. Drop the rows that do not apply.

1.4 Project Objectives and Scope

State the objectives as a numbered list of concrete, verifiable goals (Chapter 5 evaluates against them), then the scope: what is included and what is explicitly excluded.

Table 1.1: Complex engineering problem characteristics (P1–P7) and evidence from this project

Code	Definition	Evidence from this project
P1	Depth of knowledge required. Cannot be resolved without in-depth engineering knowledge at the level of one or more of K3, K4, K5, K6, or K8, which allows a fundamentals-based, first-principles analytical approach.	<i>Which of K3–K8, and where applied (mandatory)</i>
P2	Range of conflicting requirements. Involves wide-ranging or conflicting technical, engineering, and other issues.	<i>The conflicting requirements and trade-offs</i>
P3	Depth of analysis required. Has no obvious solution and requires abstract thinking and originality in analysis to formulate suitable models.	<i>Why routine methods were insufficient</i>
P4	Familiarity of issues. Involves infrequently encountered issues.	<i>The non-routine issues</i>
P5	Extent of applicable codes. Is outside problems encompassed by standards and codes of practice for professional engineering.	<i>Where standards did not cover the problem</i>
P6	Extent of stakeholder involvement and conflicting requirements. Involves diverse groups of stakeholders with widely varying needs.	<i>The stakeholder groups and their conflicting needs</i>
P7	Interdependence. Is a high-level problem including many component parts or sub-problems.	<i>The sub-problems and their dependencies</i>

Table 1.2: Knowledge profiles referenced by P1

Code	Description
K3	A systematic, theory-based formulation of engineering fundamentals required in the engineering discipline.
K4	Engineering specialist knowledge that provides theoretical frameworks and bodies of knowledge for the accepted practice areas in the engineering discipline; much is at the forefront of the discipline.
K5	Knowledge that supports engineering design in a practice area.
K6	Knowledge of engineering practice (technology) in the practice areas in the engineering discipline.
K8	Engagement with selected knowledge in the research literature of the discipline.

Chapter 2

Preliminary Research

2.1 Literature Review

Review the research literature relevant to the problem: the established methods, their results, and their limitations. Synthesise the findings rather than listing papers one by one, and state what the literature establishes and what it leaves open.

2.2 Existing Solutions and Technologies

Survey the products, systems, and technologies already available in this space, including anything the industry partner already uses: what they do, their strengths, and their limitations. Conclude with the gap this project addresses. Candidate solutions for this specific problem are formulated later, in Section 3.3.

2.3 Market and User Research

Identify who would use the solution and establish the demand for it: the size and characteristics of the user base or market, what users currently do instead, and what they need. Report the evidence gathered (surveys, interviews, discussions with the industry partner, published data). The financial implications are analysed in Section 6.1.3.

2.4 Feasibility Study

Assess whether the project is feasible along the dimensions that matter to it: technical (available methods, data, and computing resources), economic (cost against expected benefit), operational (whether the intended users and organisation can adopt it), and legal or regulatory. State the conclusion and any assumption the project depends on.

Chapter 3

Requirements Analysis

3.1 Project Objectives and Constraints

3.1.1 Problem Context and Origin

The project originated with Spectrum Software & Consulting Pvt. Ltd. (SSCL), a software development organisation. Engineering leadership at SSCL monitored the health of their software projects through four to five separate tool dashboards such as a version control platform (e.g., Github), an issue-tracking and sprint-planning platform (e.g., Jira), a static code-analysis service (e.g., SonarQube), and a CI/CD service (e.g., Jenkins). Each dashboard presented its own metrics in its own vocabulary, with no shared notion of whether a project was, overall, in good or poor health. Assessing the state of a single project required visiting every dashboard in turn and mentally reconciling the results; assessing a portfolio of projects this way was impractical.

SSCL proposed a platform that would ingest data from these separate tools, translate heterogeneous raw metrics into a common, comparable scale, and present the result in a single view. The system described in this report addresses that problem. It is explicitly positioned as a trend indicator system rather than a real-time monitoring tool. Its purpose is to reveal how projects and teams are trending over weeks and months, not to report the state of a build in the last five minutes.

3.1.2 Requirements Elicitation

Requirements were gathered through three complementary channels. The primary channel was a series of meetings with the Chief Technical Officer of SSCL, who originated the concept and articulated the operational pain point, the tools in use, and the decisions the system was intended to support. A secondary channel was an intern at SSCL with prior exposure to the concept, who provided practical grounding on how the organisation's teams actually work day to day. The third channel was the team's own analysis such as study of the public APIs exposed by the candidate tools to establish which metrics were obtainable in practice, and derivation of a scoring model from that feasible metric set. Throughout, the university supervisor provided guidance on scope, methodology and academic rigour.

3.1.3 Stakeholders and Their Expectations

Table 3.1: Stakeholders and their principal expectations

ID	Stakeholder	Role	Principal expectations
SH-01	SSCL leadership	Client; originator; primary requirement source	A single consolidated view replacing four to five dashboards; comparable scores across projects; early visibility of declining projects
SH-02	Engineering managers and project managers	Primary end users	Status at a glance; the ability to drill into a score that looks wrong; low operational overhead
SH-03	Developers employed by SSCL	Data subjects and survey respondents	Assurance that the system is not an instrument of individual surveillance or ranking; minimal interruption; the ability to answer candidly without attribution
SH-04	Company administrator	Tenant and credential owner	Control over access tokens, workspace membership and tool configuration; assurance that credentials are not exposed
SH-05	University supervisor	Academic oversight	Methodological rigour, documented decision-making, demonstrable evaluation
SH-06	External tool and service providers	Constraint setters	Adherence to their authentication models, rate limits, free-tier quotas and terms of service
SH-07	Development team	Implementers	A scope deliverable by five students within two semesters

3.1.4 Conflicting Expectations and Their Resolution

Several stakeholder expectations are in genuine tension. Each conflict was resolved by an explicit requirement rather than left to implementation judgement.

Table 3.2: Conflicting stakeholder expectations and their resolution

#	Conflict	Resolution	Encoded by
1	SH-01 seeks insight into how teams are performing; SH-03, the same organisation's employees, require that the system not attribute opinions to individuals	Qualitative feedback is collected anonymously, with no stored link between a respondent and their answers, and aggregate insight is withheld below a minimum response count	NFR-07, NFR-08
2	SH-01 and SH-02 would benefit from frequent team feedback; SH-03 experience repeated surveys as interruption and survey fatigue	Survey frequency is capped per project per month, and a cooldown is enforced per developer across all projects, with fair rotation for developers on several projects	FR-33, FR-31
3	SH-01 expects current data; SH-06 impose rate limits that make continuous polling infeasible under free-tier quotas	The product is positioned as a trend indicator on a scheduled cadence rather than a real-time monitor, with on-demand sync available when a current reading is needed	FR-13, FR-18, NFR-16
4	SH-01 expects every project to carry a comparable score; in practice most projects have only a subset of the four tool categories configured	Scores are computed from whichever inputs are available, with the weight of absent inputs redistributed proportionally rather than treated as zero	FR-22
5	SH-04 must be able to verify and rotate access tokens; the same tokens must never be casually exposed	Credentials are masked by default in all responses and revealed only through an explicit, administrator-restricted action, and are encrypted at rest	FR-12, NFR-01, NFR-04
6	SH-01 expects the analytical capability that AI features provide; C-03 (in Section 3.1.8) permits no expenditure, and external AI services may be unavailable	AI-dependent features are optional, the system degrades to non-AI behaviour when such services are unconfigured or unavailable, rather than failing	NFR-13

#	Conflict	Resolution	Encoded by
7	SH-01 requested coverage of their full toolchain; SH-07 capacity permits only a subset within the available time	A representative connector from each of the four tool categories was implemented, behind an abstraction that permits further providers to be added without altering scoring logic	NFR-21
8	SH-05 values methodological rigour and documentation; SH-01 values a working, maintainable product	Both were treated as delivery criteria: design decisions are documented and the scoring rules are specified and unit-tested, which serves the academic requirement while improving maintainability for the client	NFR-22, NFR-23

3.1.5 Project Objectives

Table 3.3: Project objectives

ID	Objective
O-01	Consolidate engineering metrics from independent tools into a single dashboard, removing the need to consult each tool's own dashboard for routine status assessment
O-02	Normalise heterogeneous raw metrics into comparable, interpretable health scores on a uniform 0–100 scale across seven quality dimensions
O-03	Keep every score explainable and auditable, so that a manager can determine which underlying metrics produced a score and how much each contributed
O-04	Capture qualitative team signal via survey that quantitative metrics cannot express, without compromising the anonymity of individual respondents
O-05	Close the management loop by recording the actions taken in response to identified problems and reviewing their effectiveness after a defined interval

ID	Objective
O-06	Accumulate project health history automatically on a fixed schedule, so that trend data is evenly spaced and does not depend on users manually triggering synchronisation.
O-07	Remain extensible to additional tools and providers without modification of the core scoring logic

Objectives O-03 and O-05 distinguish the system from a conventional metrics dashboard, the first makes scores accountable rather than opaque, and the second records the managerial response alongside the measurement, enabling later assessment of whether interventions worked.

3.1.6 Functional Requirements

Authentication, Tenancy and Access Control

Table 3.4: Functional requirements: authentication, tenancy and access control

ID	Requirement
FR-01	The system shall allow a new organisation to register, creating a company and an initial administrator account, with the administrator's email address verified by a one-time code before the account is created
FR-02	The system shall authenticate users by email address and password and maintain an authenticated session
FR-03	The system shall allow a user to reset a forgotten password through a single-use emailed link, and shall invalidate all of that user's existing sessions upon reset
FR-04	The system shall allow an administrator to invite a person to a project by email address, using a single-use invitation that the recipient accepts either by registering or by accepting while already authenticated
FR-05	The system shall support two roles, administrator and member, where a member may access only the projects to which they are assigned and an administrator may access all projects within their company
FR-06	The system shall allow an administrator to remove a member from a project

Workspace and Project Configuration

Table 3.5: Functional requirements: workspace and project configuration

ID	Requirement
FR-07	The system shall allow an administrator to create a workspace defined by a version-control provider, an organisation identifier and an access token
FR-08	The system shall list the repositories reachable with a supplied access token before any data is stored, so the administrator can confirm the token's scope
FR-09	The system shall import selected repositories as projects belonging to the workspace
FR-10	The system shall allow further repositories to be imported into an existing workspace, excluding those already imported
FR-11	The system shall allow an administrator to configure per-project integrations for project management, code quality and CI/CD tools, with the version-control credential inherited from the workspace
FR-12	The system shall mask credential values in all responses by default, and shall reveal a credential only through an explicit administrator-restricted request

Metric Ingestion

Table 3.6: Functional requirements: metric ingestion

ID	Requirement
FR-13	The system shall allow a user to trigger an immediate synchronisation of a project across all of its configured tools
FR-14	The system shall retrieve metrics from a version-control platform, an issue-tracking platform, a static code-analysis service and a CI/CD service
FR-15	The system shall record each synchronisation as an immutable, timestamped project snapshot with the metrics retrieved from each tool
FR-16	The system shall report synchronisation progress to the user interface in real time, indicating the status of each tool individually
FR-17	The system shall allow a user to navigate away from or reload the page during a synchronisation and reattach to its progress

ID	Requirement
FR-18	The system shall automatically synchronise every configured project on a configurable daily schedule without user intervention
FR-19	The system shall complete a synchronisation and record the data successfully retrieved when one or more individual tools fail, reporting the outcome as partial

Health Scoring and Presentation

Table 3.7: Functional requirements: health scoring and presentation

ID	Requirement
FR-20	The system shall compute seven health scores per snapshot — security, reliability, maintainability, CI/CD and deployment health, team health, engineering process, and planning and execution — each on a 0–100 scale where a higher value indicates better health
FR-21	The system shall compute an overall health score for each snapshot from the seven dimension scores
FR-22	The system shall compute scores from the metrics actually available for a snapshot, redistributing the weight of unavailable metrics across those present
FR-23	The system shall persist computed scores against the snapshot from which they were derived
FR-24	The system shall present a portfolio view listing all accessible projects with their overall score, dimension scores and trend
FR-25	The system shall present a per-project dashboard showing the current score, its trend, the dimension scores and their history over time
FR-26	The system shall present, on request, a breakdown of any dimension score identifying the contributing metrics, their measured values, their applied weights and their individual contributions

Team Feedback Surveys

Table 3.8: Functional requirements: team feedback surveys

ID	Requirement
FR-27	The system shall generate survey questions automatically, informed by the project's current health scores, their trend since the previous synchronisation, and notable operational conditions detected in the latest metrics
FR-28	The system shall filter generated questions for duplication and assess their quality, discarding those below a configurable quality threshold
FR-29	The system shall allow an authorised reviewer to edit the generated questions before dispatch, and shall prevent further editing once the survey has been distributed
FR-30	The system shall distribute one scheduled pulse survey per project per month, at a time selected within a configurable window and fixed once assigned
FR-31	The system shall allow an authorised user to dispatch an additional survey on demand, subject to a configurable monthly limit per project
FR-32	The system shall distribute a survey as a single anonymous link, broadcast to configured team communication channels and emailed to eligible project developers
FR-33	The system shall not email a developer a survey within a configurable cooldown period of their previous survey email, and shall rotate fairly between the projects a developer belongs to
FR-34	The system shall accept anonymous responses through the time-limited link that expires at a configurable deadline
FR-35	The system shall close a survey at its deadline or on demand and produce an analysis comprising dimension scores, recurring themes, a narrative summary and a per-question summary
FR-36	The system shall flag a project as due for a survey when defined health scores fall below configured thresholds

Management Action Log

Table 3.9: Functional requirements: management action log

ID	Requirement
FR-37	The system shall allow a user to record a management action comprising the problem observed, its assessed cause, the action taken, the date, and the projects affected
FR-38	The system shall list recorded actions per project and across the company, scoped to the user's role
FR-39	The system shall allow actions to be searched by keyword, and shall additionally offer a semantic search that retrieves conceptually related actions
FR-40	The system shall prompt the author of an action to rate its effectiveness after a defined review interval, and shall allow that review to be deferred
FR-41	The system shall allow a member to modify or delete actions they recorded, and an administrator to do so for any action within their company

3.1.7 Non-Functional Requirements

Table 3.10: Non-functional requirements

ID	Requirement
<i>Security</i>	
NFR-01	Access tokens and credential material shall be encrypted at rest
NFR-02	User passwords shall be stored only as salted cryptographic hashes and shall never be recoverable
NFR-03	Session identifiers shall be transmitted in cookies inaccessible to client-side scripts, shall expire after a defined period of inactivity, and shall be revocable
NFR-04	Credential values shall not appear in API responses except through the explicit reveal action of FR-12, and shall never be written to application logs
NFR-05	Endpoints accessible without authentication shall be rate-limited
NFR-06	Survey access links shall be tamper-evident, such that modification of an embedded identifier or deadline invalidates the link

ID	Requirement
<i>Privacy</i>	
NFR-07	A survey response shall not be attributable to the individual who submitted it, and no stored association between respondent identity and response content shall exist
NFR-08	Aggregate survey insight shall be reported only where the number of responses meets a configured minimum
NFR-09	Data transmitted to third-party analysis services shall not include the names of individuals or identifiers of specific work items
<i>Reliability</i>	
NFR-10	The failure of one tool during a synchronisation shall not prevent the remaining tools from being processed and recorded
NFR-11	Background jobs shall be retried automatically on failure with an increasing delay between attempts
NFR-12	Scheduled synchronisation shall be idempotent, such that a repeated or retried schedule trigger does not duplicate work for the same project and time slot
NFR-13	The system shall degrade gracefully when optional external services are unconfigured or unavailable, substituting reduced functionality rather than failing
NFR-14	Multi-step operations that cannot be performed atomically shall reverse their partial effects on failure
<i>Performance and Efficiency</i>	
NFR-15	Calls to external APIs shall be issued with bounded concurrency
NFR-16	The system shall observe the rate limits published by external providers, and shall stagger projects that share a credential so that a scheduled run does not exhaust a single credential's quota
NFR-17	Dashboard views shall be served from stored snapshot data and shall not block on live calls to external tools
<i>Usability</i>	
NFR-18	A manager shall be able to assess routine project status without opening any of the underlying tools

ID	Requirement
NFR-19	The progress of a running synchronisation shall be visible to the user, with per-tool status
NFR-20	Any presented score shall be explainable on demand in terms of its contributing metrics
<i>Maintainability</i>	
NFR-21	Support for an additional tool provider shall be addable without modification of the scoring logic
NFR-22	The scoring rules for each health dimension shall be documented and covered by automated tests
NFR-23	Every change shall be validated automatically for type correctness, static analysis compliance, successful build and passing tests before it is merged
<i>Portability and Deployability</i>	
NFR-24	All environment-specific configuration shall be supplied externally, with no credential or endpoint hard-coded in source
NFR-25	The server components shall be deployable as containers
NFR-26	Scheduling shall be configurable to an arbitrary named time zone, independent of the host's clock

3.1.8 Constraints

Table 3.11: Project constraints

ID	Category	Constraint and implication
C-01	Time	Development spanned two academic semesters, approximately twelve months, undertaken alongside concurrent coursework rather than full-time. This required incremental delivery and forced explicit deferral of lower-priority capability
C-02	Human resources	The team comprised five students with no dedicated operations, quality-assurance or design specialists; all such responsibilities were absorbed by the same five members

ID	Category	Constraint and implication
C-03	Budget	No monetary budget was available. Every external service — database, cache, hosting, AI inference, email delivery and code analysis — had to operate within a free service tier. This constrained hosting to a single application instance without redundancy, and bounded the volume of AI inference and external API traffic the system could consume
C-04	Platform	The implementation targets a Node.js runtime with TypeScript. Persistence uses a managed PostgreSQL service accessed through a REST client, which does not expose multi-statement transactions across tables; operations spanning several tables therefore require explicit compensating logic. An in-memory data store is required for both job queuing and session storage, making it a hard runtime dependency
C-05	Data availability	The system can only measure what the external tools expose. Several intended metrics are unobtainable in practice such as security alert counts are unavailable where the repository has not enabled the relevant scanning feature, test coverage is reported only where the project's pipeline publishes a coverage report, and certain issue-tracker fields are instance-specific custom fields whose identifiers vary between organisations
C-06	Data history	No historical backfill is possible from the source tools for most metrics. Trend data therefore accumulates only from the first synchronisation onward, meaning the system's analytical value increases over time and is limited immediately after adoption
C-07	Integration access	The system operates strictly read-only against the partner's tools using access tokens, with no ability to install agents, configure webhooks or otherwise modify the partner's infrastructure
C-08	Deployment	The system is deployed to managed cloud platforms which includes a container platform for the server components, a static hosting platform for the client application, and managed cache and database services. At the time of writing it is hosted and operational but has not yet been handed over to SSCL for production use

ID	Category	Constraint and implication
C-09	Confidentiality	Work is conducted under a non-disclosure agreement with SSCL, which governs the handling of their data and the disclosure of information in this report. The obligations arising from it are addressed in Section 3.2

3.2 Regulatory Requirements and Standards

3.2.1 Scope and Approach

This section identifies the legal obligations, engineering standards and codes of practice that govern the system, states why each applies, and records how the design responds to it. Three categories are distinguished, because they bind the project with differing force. Contractual obligations arising from the agreement with SSCL are binding without qualification. Statutory data-protection obligations are treated as a reference model rather than a directly binding regime, for the reasons given in Section 3.2.2. Engineering standards are adopted voluntarily as recognised good practice, and conformance to them is claimed only where it can be evidenced.

Where a standard is only partially satisfied, this is stated explicitly rather than omitted. Section 3.2.8 consolidates the identified gaps, each of which is either mitigated, accepted with justification, or carried forward as work required before the system is handed over for production use.

3.2.2 Data Protection and Privacy

Why it applies. The system processes data derived from identifiable individuals. Version-control metrics attribute commits, reviews and pull requests to named contributors; issue-tracker metrics reference assignees, and the survey subsystem collects free-text opinions authored by SSCL's employees. For data protection and privacy, we followed GDPR principles from the start, since building to the stricter rule was safer than redesigning the system later.

How the design complies. Five GDPR principles were treated as design constraints.

- **Data minimisation:** It governs what leaves the system. The prompts submitted to the external language model are constructed so as to exclude personal names and work-item identifiers, carrying only aggregate scores and depersonalised descriptions of operational conditions.

- **Purpose limitation:** It is reflected in the metric set, which was restricted to indicators of project and process health rather than measures of individual productivity.
- **Storage limitation and integrity:** These are served by encrypting credential material at rest and restricting its retrieval (NFR-01, NFR-04).
- **Anonymisation:** It is enforced structurally rather than by policy. The survey response record carries a randomly generated submission identifier and holds no foreign key to any user, so responses cannot be re-associated with respondents even by an administrator with full database access.
- **Lawfulness and transparency:** In respect of automated processing, these were addressed by disclosing to SSCL that project health context is transmitted to a third-party language-model service operating under free-tier terms (Section 3.2.4).

Identified gaps. The system provides no data-subject access, rectification or erasure mechanism, and defines no retention schedule for collected metrics or survey responses. Both are recorded as G-01 and G-02 in Section 3.2.8.

3.2.3 Partner Policy and Contractual Obligations

Why it applies. Work was conducted under a non-disclosure agreement with SSCL. The agreement governs the handling of their source-repository data, issue-tracker contents, access credentials and internal process information, and constrains what may be disclosed in this report.

How the design complies. Access credentials supplied by SSCL are encrypted at rest, masked in all API responses by default, retrievable only through an explicit administrator-restricted action, and excluded from application logs (NFR-01, NFR-04). Where a credential is used as a grouping key during scheduled synchronisation, it is first reduced to a one-way hash so that the operational logs never contain the credential itself. The system integrates strictly read-only, requesting only the API scopes necessary for metric retrieval, and holds no capability to modify the partner's repositories, pipelines or issue tracker (C-07). In this report, identifying details of SSCL are handled according to the disclosure terms of the agreement.

3.2.4 Third-Party Terms of Service as Codes of Practice

Why it applies. The system's core function depends on six external services, each imposing contractual usage terms, authentication requirements and quota limits. Because all are consumed under free service tiers (C-03), their terms constrain the design directly rather than being a matter of billing.

How the design complies. Rate limits published by the version-control provider are respected through a shared throttled API client that observes the provider's own rate-limit response headers, applies bounded concurrency, and abandons a request rather than blocking a worker indefinitely when a limit reset would require an extended wait (NFR-15, NFR-16). Scheduled synchronisation groups projects that share an access credential and staggers them in time, so that a single credential's quota is not exhausted by a burst of concurrent runs.

The terms governing the language-model service warrant specific note. The service is consumed under its free tier, whose terms permit submitted inputs to be used by the provider for product improvement. The project responded in three ways: the content transmitted is constrained by the data-minimisation measures of Section 3.2.2; the limitation was documented in the project's own technical reference as an explicit operating caution; and SSCL was informed that the free tier is used for question generation and response analysis, so that the decision to proceed was made by the data controller rather than assumed by the development team.

Identified gap. Free-text survey responses are authored by developers and cannot be validated against the data-minimisation rules before transmission; a respondent may volunteer identifying information within their own answer. This residual risk is recorded as G-03.

3.2.5 Application Security: OWASP

Why it applies. The system is an internet-facing web application that custodies third-party access credentials and exposes one endpoint family to unauthenticated users. The OWASP Top 10 (2021) was adopted as the reference catalogue of application security risks, and the OWASP Application Security Verification Standard (ASVS) Level 1 as the corresponding verification framework.

Table 3.12: Design response to the OWASP Top 10 (2021)

Risk	How the design responds
A01 Broken Access Control	Every data access is scoped to the requesting user's company; administrative operations verify the administrator role; members are additionally verified as assigned to the project requested. Where a resource is addressed by a surrogate identifier, its ownership by the named project is confirmed before it is served, so that identifiers cannot be enumerated across tenants.

Risk	How the design responds
A02 Cryptographic Failures	Credential material is encrypted at rest using AES-256-GCM with a per-record initialisation vector. Passwords are stored only as bcrypt hashes. Session cookies are set <code>httpOnly</code> , <code>secure</code> in production deployments, and <code>sameSite</code> -constrained. Transport encryption is terminated by the hosting platforms
A03 Injection	Database access is performed exclusively through a parameterised query builder; no SQL is assembled by string concatenation. User-supplied search terms are sanitised of pattern metacharacters before use in pattern matching. Any user-supplied text placed into an outgoing HTML email such as a person's name is escaped first, so that characters with special meaning in HTML are rendered as plain text rather than interpreted as markup.
A04 Insecure Design	Protection against misuse is built into the design rather than added later. Survey dispatch is bounded by per-project quotas and per-recipient cooldowns, unauthenticated endpoints are rate-limited, survey links carry an expiry that is verified on every use, and respondent anonymity is enforced by the absence of a linking column rather than by access rules
A05 Security Misconfiguration	Standard security response headers are applied by middleware. Cross-origin access is restricted to a single configured origin with credentials enabled; no wildcard origin is used. All secrets and endpoints are supplied by environment configuration, with none committed to source (NFR-24)
A06 Vulnerable and Outdated Components	Dependency versions are pinned by lockfile and installed reproducibly in continuous integration.
A07 Identification and Authentication Failures	Authentication failures return an identical message whether the address is unknown or the password is wrong, preventing account enumeration. Self-registration requires a one-time emailed verification code. Password-reset and invitation tokens are single-use. A password reset revokes every existing session for that user. Sessions expire on a rolling inactivity window

Risk	How the design responds
A08 Software and Data Integrity Failures	Survey access tokens are sealed with an AES-GCM authentication tag, so that modification of the embedded survey identifier or deadline causes decoding to fail rather than to succeed with altered values. Every change is validated by an automated pipeline before merge (NFR-23)
A09 Security Logging and Monitoring Failures	The application emits structured logs throughout the request and job lifecycle. Credential values are never logged; where a credential must serve as a grouping key it is reduced to a truncated one-way hash first. (See gap G-04)
A10 Server-Side Request Forgery	Outbound requests target provider API endpoints. The issue-tracker base URL is derived from a pasted board URL validated against a pattern that constrains it to an HTTPS host, and its use is confined to authenticated API calls whose responses are parsed as structured data and never returned verbatim to the client. (See gap G-05)

3.2.6 Accessibility: WCAG 2.1 Level AA

Why it applies. The client application is the sole interface through which managers perform routine assessment (NFR-18). As a web interface intended for daily professional use, it falls within the scope of the Web Content Accessibility Guidelines, against which Level AA is the conventional target for non-public professional software.

How the design complies. Interactive elements that are not natively focusable carry explicit roles, are included in the tab order, and respond to keyboard activation as well as pointer input, satisfying the keyboard-operability criteria. State-bearing controls expose their state programmatically through the corresponding ARIA attributes. Non-text status is never conveyed by colour alone, every health score is rendered as a numeric value alongside its colour coding, so that the information survives both monochrome rendering and colour-vision deficiency. Page structure uses semantic headings, with a visually hidden heading provided where the visual design does not call for one.

Identified gap. Conformance has not been formally audited, whether by automated tooling or by assistive-technology testing; contrast ratios have not been measured against the Level AA threshold; and the charting library used for trend visualisation offers limited screen-reader

semantics. Conformance is therefore claimed as partial and unverified, and is recorded as G-06.

3.2.7 Software Engineering Standards

Table 3.13: Engineering standards adopted and their application

Standard	Why it applies	How it is applied
ISO/IEC 25010 (SQuaRE product quality model)	Provides an accepted vocabulary for expressing quality requirements, avoiding an ad hoc classification of non-functional needs	The non-functional requirements of Section 3.1.7 are organised by its quality characteristics which are security, reliability, performance efficiency, usability, maintainability and portability
ISO/IEC/IEEE 29148:2018 (Requirements engineering)	Governs how requirements are expressed, independently of what they require	Requirements are stated individually, in the imperative, so as to be singular and verifiable, and are uniquely identified to permit traceability into the design, implementation and testing chapters. This standard supersedes IEEE 830, which is therefore not cited
ISO 8601 and RFC 3339 (Date and time representation)	The system reasons about time across zones: it schedules work in a named zone, stores instants from distributed processes, and renders temporal axes	All instants are stored and exchanged in UTC using the ISO 8601 profile defined by RFC 3339. A defect arising from zone-naïve storage was identified and corrected by a schema migration converting affected columns to zone-aware types, after which chart labelling and elapsed-time reporting became correct irrespective of the reader's locale

Standard	Why it applies	How it is applied
OWASP ASVS Level 1	Supplies verification criteria corresponding to the risk catalogue of Section 3.2.5	Adopted as the yardstick against which the security posture was self-assessed. A formal ASVS assessment was not performed (see gap G-07)

3.2.8 Compliance Summary and Identified Gaps

Table 3.14 consolidates the shortfalls identified above. Each is classified as *accepted*, where the gap is justified by a project constraint and carries tolerable residual risk; or *outstanding*, where remediation is required before the system is handed over to [PARTNER] for production use.

Table 3.14: Identified compliance gaps and their disposition

ID	Gap	Obligation affected	Disposition
G-01	No data-subject access, rectification or erasure mechanism is exposed	Data protection	Outstanding. Accepted within the project scope for now, but should be implemented in future.
G-02	No retention schedule is defined for metrics, snapshots or survey responses	Data protection	Outstanding. To be agreed with SSCL as the data controller
G-03	Free-text survey answers may contain identifying information volunteered by the respondent and cannot be filtered before transmission to the external language-model service	Data protection; third-party terms	Accepted. Mitigated by instructing respondents that responses are anonymous and by prompt-level instructions excluding identifying content from generated output
G-04	Logs are emitted in structured form but are not aggregated centrally, and no alerting is configured on security-relevant events	OWASP A09	Accepted. Attributable to the absence of budget for log-management infrastructure (C-03)

ID	Gap	Obligation affected	Disposition
G-05	The issue-tracker base URL is user-supplied and constitutes a residual server-side request forgery surface, constrained but not eliminated by pattern validation	OWASP A10	Accepted. Residual risk is limited. The endpoint requires administrator privileges, responses are parsed rather than relayed, and no response body is returned to the caller
G-06	WCAG 2.1 Level AA conformance is partial and has not been audited; contrast ratios are unmeasured and chart components offer limited assistive-technology semantics	WCAG 2.1 AA	Accepted. Attributable to the absence of a dedicated design or accessibility specialist within the team (C-02)
G-07	No formal OWASP ASVS assessment was conducted; the standard was applied as a self-assessment reference only	OWASP ASVS L1	Accepted. Proportionate to project scale

3.3 Formulation of Solutions

Formulate multiple genuinely different solutions that could each functionally meet most requirements. Compare and evaluate them against explicit criteria from the requirements and constraints, and draw a valid conclusion that justifies the selected solution.

Chapter 4

System Design and Implementation

4.1 Functional Design and Sub-problem Partitioning

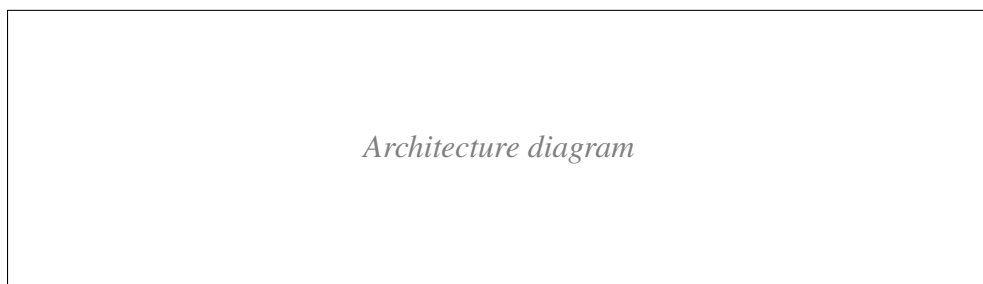


Figure 4.1: System architecture

Partition the problem into sub-problems or modules; explain each one's responsibility and how they interact. Show where the standards and codes of practice from Section 3.2 and any health, safety, or environmental considerations shaped the design.

4.2 Design Refinement and Simulation

Present the detailed design using the views that fit the project (ERD, class, sequence, DFD, API, wireframes, circuit, model). Include any design calculations or estimates made (e.g. expected load or storage), the analyses, prototypes, or simulations used to verify the design against the requirements, and how the design was refined to facilitate implementation.

4.3 Application of Tools

Justify the selection of the important tools and technologies and state their relevant limitations.

4.4 Implementation

Describe how the key modules were implemented and the development process followed (repository, version control, code review, CI/CD).

4.5 Deployment

Describe how the system is deployed and operated: the target environment and infrastructure, configuration and release process, monitoring and backup, and who operates and maintains it. State the computing resources the deployment consumes; their environmental impact is assessed in Section 6.4.

Chapter 5

Investigation and Evaluation

5.1 Experimental Investigation

Present the investigation carried out to substantiate the solution. State the research questions or hypotheses, the method and experimental design, the datasets or measurements used and how they were obtained, the baselines or points of comparison, and the metrics. Analyse and interpret the data, and synthesise the findings into conclusions that are supported by the evidence. Projects with a substantial research and development component should treat this as the core of the chapter; for development-focused projects, report the investigation that validated the main design decisions. This is the experimental work on the built system; the background research is in Chapter 2.

5.2 Performance Evaluation

Evaluate the system against every requirement and objective. Describe the setup, tools, inputs, and acceptance criteria; present the results (tests, measurements, security checks, user or partner acceptance, experiments as appropriate); state which requirements are met and clearly explain each deviation.

5.3 Deviations and Design Revisions

For each deviation, give the technical analysis of its cause and the design revision made to achieve compliance, or explain why it was not revised.

Chapter 6

Project Management, Teamwork, and Impact

6.1 Project Management and Finance

6.1.1 Planning and Risk Management

Present the plan: phases, milestones, task distribution, and schedule, noting where actual progress differed. List the major risks and how they were mitigated.

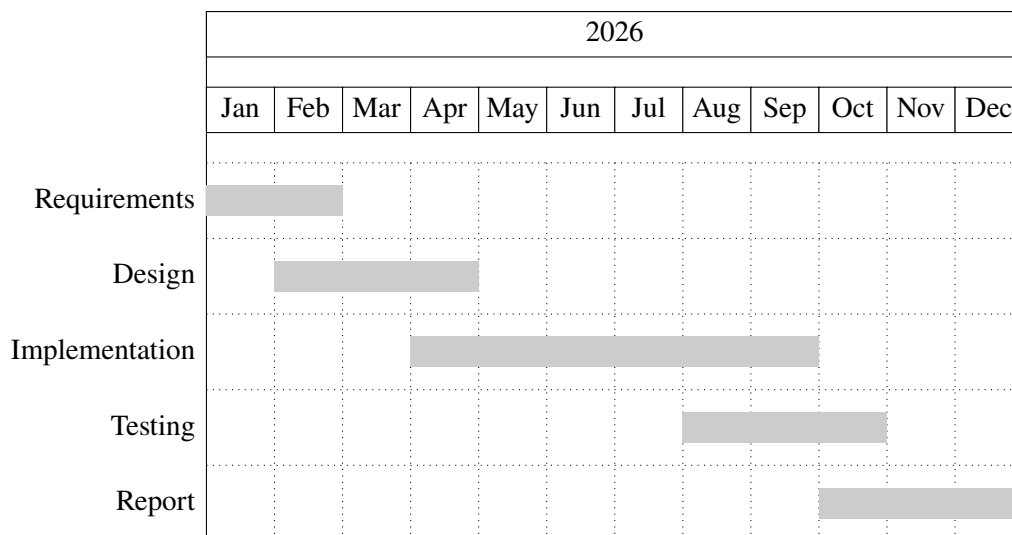


Figure 6.1: Project schedule

6.1.2 Budgeting and Resource Identification

Identify the resources required (people, hardware, software, cloud and API services, data) with an itemised budget.

6.1.3 Economic Analysis and Financial Prospecting

Evaluate the financial prospect of the project with clear interpretation: development and operating cost, the potential users or market established in Section 2.3, and how the solution could generate value or revenue.

6.1.4 Sustainability in Business and Commercialisation

Explain how the solution could remain viable after the course: the commercialisation or deployment path (e.g. with the industry partner) and who would maintain and operate it.

6.2 Individual and Teamwork

6.2.1 Participation and Contribution

For each member, give the role, specific contributions, participation in discussions and decision-making, and whether responsibilities were completed on time.

6.2.2 Collaboration and Conflict Resolution

Describe how the team collaborated and kept a constructive atmosphere, and how any conflicts were identified and resolved.

6.2.3 Leadership and Direction

Explain how direction toward the goals was provided, how members' views were listened to, how the team planned for improvement after setbacks, and how members were motivated.

6.2.4 Multidisciplinary Engagement

Explain the multidisciplinary nature of the project and the team's participation in activities outside its own discipline: work with the industry partner, domain experts, end users, or other departments.

6.3 Impact on Society

Consider all impacts of the solution on society, positive and negative, covering health, safety, cultural, and legal issues explicitly. For each, state who is affected and how the design responds. Be specific to this project.

6.4 Environmental Impact and Life Cycle Sustainability

Consider the environmental and sustainability impacts over the entire life cycle: development, deployment and operation, and retirement of the system and its data. Identify the negative impacts and propose mitigation for each.

6.5 Ethics

6.5.1 Equity and Inclusivity

Show how equity and inclusivity were considered: accessibility, fairness across user groups, and who might be excluded and how that was addressed.

6.5.2 Accountability and Personal Responsibility

Show accountability and personal responsibility: who is responsible for the system's behaviour and failures, and how members took responsibility for their own work.

6.5.3 Proper Use of Intellectual Property

Show due acknowledgement of others' work, prior art, intellectual property, and copyrighted material: cite sources, list third-party code, models, and datasets with their licences, and disclose any generative AI use.

6.5.4 Professionalism and Ethical Codes

Show understanding of the engineer's role in protecting the public interest and awareness of the relevant codes of ethics (e.g. ACM, IEEE, IEB). Explain how they guided specific project decisions.

Chapter 7

Conclusion

7.1 Conclusion and Future Work

Summarise achievement against each objective, the limitations, and focused future work. Do not repeat the abstract.

7.2 Continuous Engagement and Self-directed Learning

Demonstrate engagement in staying up to date: the tools, technologies, and domain knowledge learned independently during the project, and the emerging technical literature or documentation identified and used.